codigo.py
PY 28.2KB

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Found 14 web pages

Com base na análise passo a passo do arquivo `codigo.py`, a conclusão é: **este é um malware altamente perigoso**, especificamente um **worm de propagação automática** (Worm) com funcionalidades de mineração/controle remoto. Ele não é um software normal, mas sim uma ferramenta de ataque maliciosa que se espalha automaticamente, realiza varreduras em larga escala, infecção por força bruta e tenta controlar servidores remotos.

A seguir, a análise passo a passo do comportamento malicioso central:

1. Varredura em larga escala e ataque de força bruta SSH

O arquivo embutido `run_scan.sh` e `ssh_scanner.py` formam uma cadeia de ataque automatizada:

- **Varredura Masscan**: O script primeiro chama a ferramenta `masscan` (que é um scanner de portas de código aberto) para escanear em alta velocidade toda a internet ou segmentos de IP especificados, com o objetivo de encontrar hosts com as portas 22 (SSH) ou 5522 abertas. [9]
- **Força bruta SSH**: Para os IPs descobertos, o script utiliza a biblioteca `paramiko` (biblioteca de conexão SSH do Python) e incorpora senhas predefinidas (como `LeitboGi0ro`, `123@@@`) para realizar tentativas de login por força bruta. [1] [6]

2. Propagação automática e persistência (Comportamento de Worm)

O script embutido `monitor_script.py` é o núcleo da propagação:

- **Login remoto e implantação**: Depois de obter acesso por força bruta bem-sucedido a outros servidores, ele carrega automaticamente o arquivo `bendi.py` (ou seja, este próprio script) e executa comandos remotos.

- **Instalação de backdoor**: Ele instala à força o **Komari Agent** (`komari-agent`) nos servidores invadidos. Embora o Komari seja tecnicamente uma ferramenta de monitoramento, neste script ele é usado para controle remoto malicioso, com o comando contendo parâmetros de implantação automatizada (`--auto-discovery`) e um endereço de painel (`https://sexy.pp.ua`). [8]
- **Registro e ocultação**: Ele também se comunica com a API central (`sou.pp.ua`) para registrar os IPs já infectados, evitando repetição e relatando o progresso do ataque via Telegram Bot.

3. Indicadores de inteligência de ameaças

- **Domínios maliciosos**: O endereço de download `del.sou.pp.ua` usado no script já foi sinalizado pela plataforma de inteligência de ameaças URLhaus como **domínio de download de malware**, com milhares de links maliciosos detectados. [2] [3] [7]
- **Discussões da comunidade**: Em fóruns técnicos chineses, há relatos claros de que esta é uma campanha de ataque de worm usando senhas padrão `LeitboGi0ro` , cujas características de comportamento são completamente idênticas a este código (instalação de masscan, força bruta SSH, propagação de `bendi.py` , relatório para `sou.pp.ua`). [11]

4. Mecanismo de autodestruição e ocultação

Após a implantação ser concluída, o script principal executa `rm -- '{this_script_path}'` para **se autodestruir**, tentando apagar os rastros e dificultar a análise ou remoção.

Resumo: Este código não é uma ferramenta de operação e manutenção normal, mas sim um **malware do tipo worm** com capacidades de varredura automática, força bruta, propagação de infecção e controle remoto (via instalação de Agent). Ele foi projetado para invadir servidores em larga escala e incorporá-los a uma botnet.

14 web pages

Qual é a categoria principal deste malware?

Found 12 web pages

A categoria principal deste malware é **Worm (verme de rede)**.

Ele corresponde exatamente às características de um verme automatizado: explora serviços expostos na rede (SSH), utiliza credenciais fracas predefinidas para autenticação por força bruta e, após invadir com sucesso um sistema, **replica-se automaticamente** para outros alvos, formando uma cadeia de infecção em larga escala, sem necessidade de interação do usuário. [1] [3] [5]

Evidências principais

- **Propagação automática**: Utiliza `masscan` para varredura de portas em larga escala e `ssh_scanner.py` para força bruta SSH com senhas fixas como `LeitboGi0ro`, `123@@@`, transformando hosts comprometidos em novos "pontos de salto" que continuam a escanear e infectar outros sistemas. [1] [5]
- **Implante de persistência**: Após invadir com sucesso, implanta o `bendi.py` e instala o Komari Agent como backdoor persistente, permitindo controle remoto subsequente. [1] [4]
- **Registro e ocultação**: Através de `sou.pp.ua` registra os IPs já infectados (evitando repetição) e utiliza `sexy.pp.ua` como painel de controle, ao mesmo tempo que apaga rastros locais. [1] [3]

Portanto, a categoria principal é **Worm**, e não um Trojan ou Ransomware típico.

12 web pages